THREAT DOSSIER

Persistent SSH backdoor from a trojanized Claude Code-branded extension

Campaign-specific file artifact hunting for Microsoft Defender XDR

CLASSIFICATION	Hunting query - Untested implementation sketch
CONFIDENCE	Medium
OPERATIONAL VALUE	9 / 10
PRIMARY PLATFORM	Microsoft Defender XDR
PUBLISHED	31 October 2026

CONTROLLED MASTER ADAPTATION

Eight-page A4 dossier using the controlled black, white, electric-violet, magenta and lime visual system. All visible content is threat-specific and contains no customer data.

Executive Assessment

Decision

Publish a campaign-specific hunt for exact file artifacts written by the malicious Cursor Marketplace extension. Do not promote to an alert until prevalence, path context and extension-installation provenance are validated.

Source facts

Microsoft analyzed injected JavaScript in anthropic.claude-code versions 2.1.312 and 2.1.313 served from the Cursor Marketplace on 29 October 2026. The loader attempts host discovery, SSH authorized-key modification, SSH service enablement, reverse forwarding and platform-specific persistence.

Analyst assessment

The exact hashes and filenames are useful for rapid exposure hunting. They are mutable campaign artifacts, so the logic is not durable enough for a Production candidate. A result proves only matching telemetry and requires artifact provenance and process review.

Unconfirmed

The code path does not prove every action succeeded on every host. A matching file does not prove reverse-tunnel establishment, attacker logon, credential theft or data exfiltration.

Behavior and Attack Mechanics

Stage	Confirmed behavior	Observable
Supply chain	Trojanized extension version is installed or auto-updated from Cursor Marketplace.	Extension inventory; package hash; marketplace provenance.
SSH access	Loader attempts to append an embedded public key and enable local SSH.	authorized_keys modification; SSH service changes.
C2	Loader requests reverse SSH forwarding using an embedded identity.	ssh process and outbound connection; tunnel identity files.
Persistence	macOS LaunchAgent, Linux @reboot cron, or Windows scheduled task/startup fallback.	plist, cron, scheduled task, startup script and file telemetry.

Detection hypothesis

If the trojanized extension writes its embedded SSH identity, scripts or startup artifacts, DeviceFileEvents should show the published hashes or filenames. The activity can be distinguished from legitimate files through extension-installation provenance, exact hash, user-writable path, initiating process and adjacent SSH/persistence evidence.

Telemetry and Evidence Model

Required telemetry

Microsoft Defender for Endpoint onboarded devices with DeviceFileEvents retention covering the exposure and remediation window.

Field	Reliability	Purpose
Timestamp	Documented	Event chronology
DeviceId / DeviceName	Documented	Host correlation
ActionType	Documented	File event meaning
FolderPath / FileName	Documented	Artifact location and name
SHA256	Documented; may be empty	Exact artifact match
InitiatingProcessFileName	Documented	Creator context
InitiatingProcessCommandLine	Documented; population dependent	Creator intent
InitiatingProcessAccountName	Documented	User context

Optional enrichment

Extension inventory, package provenance, DeviceProcessEvents for ssh/launchctl/schtasks, DeviceNetworkEvents for the published IP, and authentication telemetry.

Unavailable from this query

File content, authorized-key material, tunnel success, extension source and attacker authentication are not established by DeviceFileEvents alone.

Primary Hunting Logic

Hunting query - Untested implementation sketch

```
DeviceFileEvents
| where Timestamp > ago(30d)
| where SHA256 in~ (
"ecb58cb29078d9646ad1dcdbe51526f2d9cfea06be5fb2ab183e8ecc3ab6bf15",
"7e0a52885fadee05544a9e99eb18c792bec05900a5e1a66d68f8383decb0e278")
or FileName in~ (".smt", ".smtk", "smt.cmd", "smtk",
"sysmon.cmd", "com.apple.sysmond.plist")
or FileName startswith ".stk_"
| project Timestamp, DeviceId, DeviceName, ActionType, FolderPath,
FileName, SHA256, InitiatingProcessFileName,
InitiatingProcessCommandLine, InitiatingProcessAccountName
| order by Timestamp desc
```

Condition evidence

Both SHA-256 values, the exact filenames and the .stk_ prefix are published by Microsoft from its code analysis. The 30-day window covers the exposure while allowing delayed telemetry review; it is a hunting horizon, not a maliciousness threshold.

No correlation claim

The query intentionally does not infer successful SSH access, combine unrelated events, or score rarity. Every row remains an investigative lead.

Triage and Investigation

1. Verify exposure

Confirm Cursor installation and whether extension versions 2.1.312/2.1.313 were installed from the affected marketplace.

2. Preserve evidence

Collect extension package, matching files, SSH authorization files and startup objects before cleanup.

3. Establish execution

Review creator process lineage and adjacent ssh, launchctl, cron, schtasks or Startup-folder activity.

4. Establish access

Review outbound SSH/network events, local SSH authentication and post-access command execution.

5. Contain and recover

Isolate when execution/backdoor installation is supported; remove exact malicious entries, revoke sessions and rotate credentials as indicated.

Disposition rule

Escalate only when the artifact is tied to the affected extension or corroborated by persistence/SSH behavior. Close or suppress when ownership and provenance establish an authorized benign file with no adjacent suspicious activity.

False Positives and Validation

Potential overlap	Control
Generic .smt/.smtk or sysmon.cmd names	Require path, creator and extension provenance; do not alert on name alone.
Legitimate LaunchAgent with lookalike name	Inspect ProgramArguments and signer/origin; name alone is insufficient.
Security testing or remediation scripts	Tag approved test window and preserve expected artifacts.
Missing SHA256	Use exact filenames only as leads; collect file hash/content from endpoint.

Validation steps

1) Confirm DeviceFileEvents coverage on Windows, macOS and Linux test assets. 2) Verify SHA256 population for controlled file creation. 3) Measure benign prevalence of each filename and prefix. 4) Reproduce a benign extension write to confirm initiating-process context.

Success criteria

The query returns the controlled artifact with correct path, hash and initiating process, and campaign matches are attributable to the affected extension.

Rejection / failure criteria

Reject alert promotion if common benign collisions remain indistinguishable. Treat as failed telemetry validation if file events or required context are absent during controlled testing.

ATT&CK;, Conclusion and References

Technique	Direct support
T1098.004 - SSH Authorized Keys	Loader adds embedded public key.
T1572 - Protocol Tunneling	Loader requests reverse SSH forwarding.
T1053.003 - Cron	Loader attempts Linux @reboot persistence.
T1053.005 - Scheduled Task	Loader attempts Windows scheduled-task persistence.

Conclusion

This package is a high-value, time-sensitive exposure hunt with Medium confidence. It is technically defensible because the source publishes the exact artifacts and Microsoft Defender XDR fields are documented. Durability is limited: promotion requires environment validation and preferably behavioral correlation around unauthorized SSH-key modification or reverse tunneling.

References

Microsoft Security Research, 30 October 2026: hxxps://www[.]microsoft[.]com/en-us/security/blog/2026/10/30/inside-malicious-claude-code-branded-cursor-extension-persistent-ssh-backdoor/

Microsoft Learn: hxxps://learn[.]microsoft[.]com/defender-xdr/advanced-hunting-devicefileevents-table

MITRE ATT&CK;: hxxps://attack[.]mitre[.]org/techniques/T1098/004/ and hxxps://attack[.]mitre[.]org/techniques/T1572/

Document control

Classification: Hunting | Confidence: Medium | Status: Untested implementation sketch | Owner: Detection Engineering | Customer data: none | Defanging: verified